MITRE ATLAS | AML.CS0045 - Data Exfiltration via an MCP Server used by Cursor

Entry Information

ID:
AML.CS0045

Type:
Case-Study

Name:
Data Exfiltration via an MCP Server used by Cursor

URL:
https://atlas.mitre.org/studies/AML.CS0045/

Incident Date:
2025-06-24

Target:
Cursor

Actor:
Backslash Security Research Team

Description

The Backslash Security Research Team demonstrated that a Model Context Protocol (MCP) tool can be used as a vector for an indirect prompt injection attack on Cursor, potentially leading to the execution of malicious shell commands.

The Backslash Security Research Team created a proof-of-concept MCP server capable of scraping webpages. When a user asks Cursor to use the tool to scrape a site containing a malicious prompt, the prompt is injected into Cursor's context. The prompt instructs Cursor to execute a shell command to exfiltrate the victim's AI agent configuration files containing credentials. Cursor does prompt the user before executing the malicious command, potentially mitigating the attack.

Attack Procedure:
[AML.T0065] LLM Prompt Crafting: The researchers crafted a malicious prompt containing an instruction to execute the malicious shell command to exfiltrate the victim's AI agent credentials.
[AML.T0079] Stage Capabilities: The researchers created a malicious web site containing the malicious prompt.
[AML.T0068] LLM Prompt Obfuscation: The malicious prompt was hidden in the title tag of the webpage.
[AML.T0079] Stage Capabilities: The researchers launched a web server to receive data exfiltrated from the victim.
[AML.T0078] Drive-by Compromise: When a user asked Cursor to use an MCP tool to scrape the malicious website, the contents of the malicious prompt was retrieved and ingested into Cursor's context window.
[AML.T0051.001] Indirect: When the MCP server scraped the malicious web site, it returned the injected prompt to the MCP client and poisoned the context of the Cursor LLM. Cursor executed the malicious prompt embedded in the website scraped by the MCP tool.
[AML.T0053] AI Agent Tool Invocation: The prompt injection invoked Cursor's ability to call command line tools via the `run_terminal_cmd` tool.

Cursor prompted the user before executing a shell command, potentially mitigating this attack.

[AML.T0068] LLM Prompt Obfuscation: When the MCP server scraped the malicious web site, it returned the injected prompt to the MCP client and poisoned the context of the Cursor LLM. The shell command in the malicious prompt was obscured via base64 encoding, making it less clear to the user that something malicious may be executed.
[AML.T0083] Credentials from AI Agent Configuration: The shell command located the `.openapi.apiKey` and `.cursor/mcp.json` credentials files that were part of the Cursor's configuration.
[AML.T0086] Exfiltration via AI Agent Tool Invocation: The credentials files were exfiltrated to the researcher's server via a `curl` command invoked by Cursor's `run_terminal_cmd` tool.
[AML.T0048.000] Financial Harm: A bad actor could use the stolen credentials cause financial damage and could also steal other sensitive information from the victim user.

References

- Simulating a Context-Poisoning Vulnerable MCP Server: A POC — https://www.backslash.security/blog/simulating-a-vulnerable-mcp-server-for-context-poisoning